PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	• The app must securely connect sneaker buyers and sellers. • Users must be able to sign up, log in, message sellers, and manage accounts safely. • Payments must be processed quickly and securely to avoid legal and financial issues.
II. Define the technical scope	The technical scope includes APIs, PKI encryption, SHA-256 hashing, and SQL databases. The API should be prioritized for security evaluation because it handles authentication, payment requests, and database communication. Poor API security can expose sensitive user and payment data through injection attacks, broken authentication, or unauthorized access.
III. Decompose application	[Sample data flow diagram] The application allows users to search for sneakers, which sends requests from the user to the product search process. The process queries the database and returns inventory results. APIs, SQL queries, and encryption mechanisms protect data exchanged during this process.
IV. Threat analysis	**Internal threat:** A malicious or careless employee misusing database or admin access. **External threat:** A cybercriminal attempting SQL injection, credential stuffing, or session hijacking.
V. Vulnerability analysis	• Lack of prepared SQL statements could make the database vulnerable to SQL injection. • Weak session management or input validation could allow session hijacking or script injection attacks.
VI. Attack modeling	[Sample attack tree diagram]

	An attacker could exploit SQL injection vulnerabilities to access user data or hijack sessions using stolen credentials, leading to unauthorized account access and data theft.
VII. Risk analysis and impact	• End-to-end encryption using PKI (AES & RSA) • Prepared statements and input validation to prevent SQL injection • Multi-factor authentication (MFA) for user accounts • Secure session management with HTTPS and token expiration

---